

ADscan Security Report

End-to-end analysis of attack paths, privilege escalations, and compliance gaps identified during the engagement.

REPORT DATE	May 19, 2026
REPORT TYPE	Full Security Assessment Report
PROFILE	Full
DOMAINS	3 scoped

DOC · ADSCAN · ADSCAN 9.0.0

OVERALL POSTURE **CRITICAL**

1

CRITICAL

14

HIGH

4

MEDIUM

15

ATTACK PATHS

Your AD posture is **critical** — **15** high-severity findings need immediate action.

36 / 100

POSTURE SCORE

CRITICAL

0

25

50

75

100

0

PATHS TO DOMAIN ADMIN

Direct or near-direct routes to full AD takeover.

0

DOMAIN BREAKERS

Accounts whose control is equivalent to full domain compromise.

1

CRITICAL FINDINGS

Issues requiring action within the next 7 days.

SEVERITY DISTRIBUTION

22 findings



● Critical 1 ● High 14 ● Medium 4 ● Low 3

“

BOTTOM LINE

Score: 36/100 (critical). 1 critical finding require immediate action. Apply the immediate items in the remediation roadmap to clear them.

Executive findings, technical evidence, compliance mapping, and the prioritised remediation roadmap for this engagement.

CONFIDENTIAL — ADSCAN SECURITY ASSESSMENT

01 Executive Summary

High-level assessment overview for senior leadership.



OVERALL RISK POSTURE

Critical risk — immediate executive attention required

1

CRITICAL

14

HIGH

4

MEDIUM

3

LOW

15

ATTACK PATHS

SEVERITY DISTRIBUTION



● Critical (1) ● High (14) ● Medium (4) ● Low (3)

An automated Active Directory security assessment was conducted across 3 Active Directory domains. A total of 22 security findings were detected — **15 critical security gaps** were identified that represent an immediate threat to business operations and regulatory standing.

The assessment mapped **15 theoretical attack paths** that a threat actor could follow to escalate privileges within the domain. While not actively exploited during this assessment, these paths represent exploitable chains that adversaries are known to leverage.

The highest-priority issues requiring management attention are *DCSync Privilege Abuse*, *ADCS ESC9 - No Security Extension on Certificate Template*, and *ADCS ESC14 - Weak Explicit Certificate Mapping Abuse*. Full technical detail and step-by-step remediation guidance are provided in the Technical Findings section of this report.

The identified gaps have direct implications for compliance with ENS (Esquema Nacional de Seguridad) and DORA (Digital Operational Resilience Act). Regulatory frameworks in scope require effective identity and access controls — the Active Directory weaknesses documented here represent evidence of control failure that auditors and regulators would classify as significant non-conformities.

Immediate executive escalation is required. The security team should initiate emergency remediation within **30 days**. Board-level oversight of the remediation programme is recommended.

— Compliance Snapshot

At-a-glance regulatory posture across assessed frameworks. Full control-level detail in dedicated sections.



Critical Findings

Top critical and high-severity issues driving the risk posture. Full details in Technical Findings.

CRITICAL - 9.8

DCSync Privilege Abuse

The DCSync attack exploits Active Directory's directory replication protocol (MS-DRSR) to simulate the behavior of a Domain Controller requesting credential replication....

Domain: **essos.local** CWE: **CWE-269**

HIGH - 8.5

ADCS ESC9 - No Security Extension on Certificate Template

ADCS ESC9 exploits the CT_FLAG_NO_SECURITY_EXTENSION flag on a certificate template. When this flag is set, the szOID_NTDS_CA_SECURITY_EXT extension — which embeds the...

Domain: **essos.local** CWE: **CWE-269**

HIGH - 8.5

ADCS ESC14 - Weak Explicit Certificate Mapping Abuse

ADCS ESC14 abuses weak explicit certificate mappings configured through the altSecurityIdentities attribute. When administrators or applications rely on explicit mappings that...

Domain: **essos.local** CWE: **CWE-290**

02 Attack Path Analysis

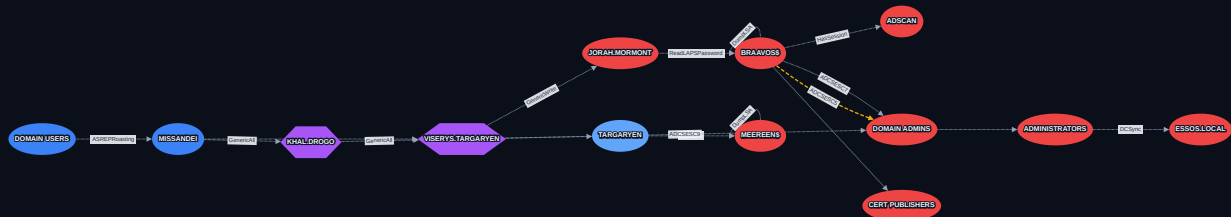
End-to-end attack chains identified in the Active Directory environment.

Attack path classification. **EXPLOITED** Successfully validated during active testing. **ATTEMPTED** Probed but not fully completed. **THEORETICAL** Mapped from configuration analysis; not actively exploited.

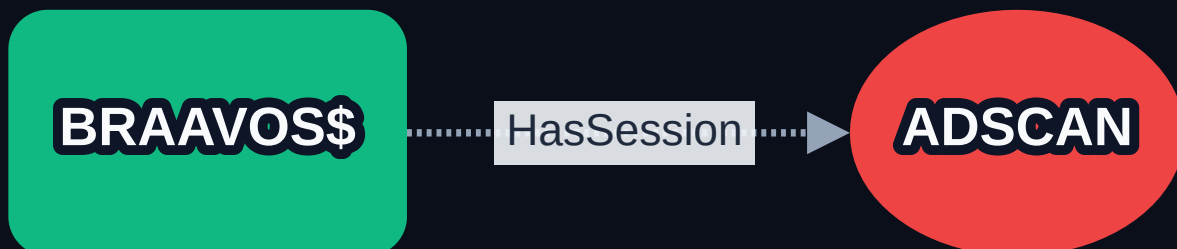
essos.local

15 PATHS

— Attack surface map · essos.local



Starting from BRAAVOSS@ESSOS.LOCAL, an attacker can reach ADSCAN@ESSOS.LOCAL in 1 step. The path abuses HasSession. This attack path is a theoretical route derived from configuration analysis.



STEP-BY-STEP BREAKDOWN

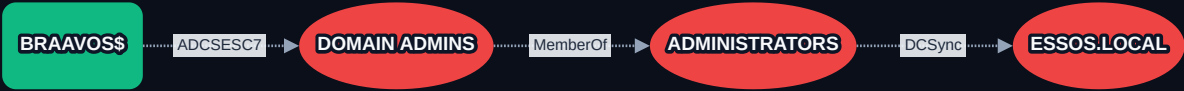
1. HASSESSION

This step indicates BRAAVOSS@ESSOS.LOCAL can perform 'HasSession' against ADSCAN@ESSOS.LOCAL, enabling further escalation.

○ DOMAIN COMPROMISED

CANONICAL TERMINUS — EVERY PATH ENDS HERE.

Starting from BRAAVOSS\$@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 3 steps. The path chains ADCS ESC7, MemberOf, and DCSync. This attack path is a theoretical route derived from configuration analysis.



STEP-BY-STEP BREAKDOWN

1. ADCSESC7

This step indicates BRAAVOSS\$@ESSOS.LOCAL can perform 'ADCS ESC7' against DOMAIN ADMINS@ESSOS.LOCAL, enabling further escalation.

2. MEMBEROF

DOMAIN ADMINS@ESSOS.LOCAL is a direct or nested member of ADMINISTRATORS@ESSOS.LOCAL. All privileges held by ADMINISTRATORS@ESSOS.LOCAL — including any onward attack-path edges — are inherited by DOMAIN ADMINS@ESSOS.LOCAL.

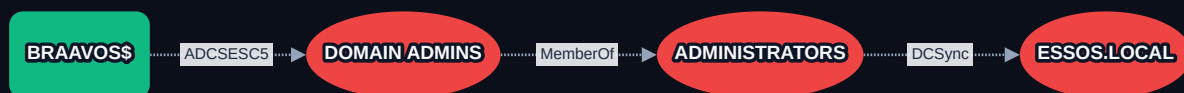
3. DCSYNC

ADMINISTRATORS@ESSOS.LOCAL holds the Replicating Directory Changes and Replicating Directory Changes All extended rights on the domain, meaning it can pull password hashes for any account via the DRSUAPI protocol (DCSync). Extracting the krbtgt hash yields persistent golden-ticket capability and full domain compromise.

○ DOMAIN COMPROMISED

CANONICAL TERMINUS — EVERY PATH ENDS HERE.

Starting from BRAAVOSS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 3 steps. The path chains ADCS ESC5, MemberOf, and DCSync. This attack path is mapped but not actionable via ADscan's current toolkit.



STEP-BY-STEP BREAKDOWN

1. ADCSESC5

This step indicates BRAAVOSS@ESSOS.LOCAL can perform 'ADCS ESC5' against DOMAIN ADMINS@ESSOS.LOCAL, enabling further escalation.

2. MEMBEROF

DOMAIN ADMINS@ESSOS.LOCAL is a direct or nested member of ADMINISTRATORS@ESSOS.LOCAL. All privileges held by ADMINISTRATORS@ESSOS.LOCAL — including any onward attack-path edges — are inherited by DOMAIN ADMINS@ESSOS.LOCAL.

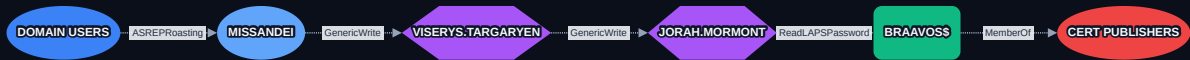
3. DCSYNC

ADMINISTRATORS@ESSOS.LOCAL holds the Replicating Directory Changes and Replicating Directory Changes All extended rights on the domain, meaning it can pull password hashes for any account via the DRSUAPI protocol (DCSync). Extracting the krbtgt hash yields persistent golden-ticket capability and full domain compromise.

○ DOMAIN COMPROMISED

CANONICAL TERMINUS — EVERY PATH ENDS HERE.

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach CERT PUBLISHERS@ESSOS.LOCAL in 5 steps. The path chains ASREPROasting, GenericWrite, ReadLAPSPassword, and MemberOf. This attack path is a theoretical route derived from configuration analysis.



STEP-BY-STEP BREAKDOWN

1. ASREPROASTING

ASREPROasting targets accounts — in this path, MISSANDEI@ESSOS.LOCAL — that have Kerberos pre-authentication disabled (DONT_REQ_PREAUTH flag). Any unauthenticated attacker (including DOMAIN USERS@ESSOS.LOCAL) can request an AS-REP message encrypted with the account's password-derived key and crack it offline. Successful cracking yields full credentials for MISSANDEI@ESSOS.LOCAL.

2. GENERICWRITE

GenericWrite gives user MISSANDEI@ESSOS.LOCAL the ability to modify most attributes of user VISERYS.TARGARYEN@ESSOS.LOCAL. Typical abuse paths include writing msDS-KeyCredentialLink (Shadow Credentials) to obtain a PKINIT certificate, setting a servicePrincipalName to enable Kerberoasting, or modifying scriptPath / msDS-AllowedToActOnBehalfOfOtherIdentity. Any of these leads to full compromise of VISERYS.TARGARYEN@ESSOS.LOCAL.

3. GENERICWRITE

GenericWrite gives user VISERYS.TARGARYEN@ESSOS.LOCAL the ability to modify most attributes of user JORAH.MORMONT@ESSOS.LOCAL. Typical abuse paths include writing msDS-KeyCredentialLink (Shadow Credentials) to obtain a PKINIT certificate, setting a servicePrincipalName to enable Kerberoasting, or modifying scriptPath / msDS-AllowedToActOnBehalfOfOtherIdentity. Any of these leads to full compromise of JORAH.MORMONT@ESSOS.LOCAL.

4. READLAPSPASSWORD

The ReadLAPSPassword edge means JORAH.MORMONT@ESSOS.LOCAL has the Control Access right on the ms-Mcs-AdmPwd (or ms-LAPS-Password) attribute of BRAAVOS\$@ESSOS.LOCAL. JORAH.MORMONT@ESSOS.LOCAL simply queries the attribute via LDAP to retrieve the local Administrator password in cleartext and pivots to BRAAVOS\$@ESSOS.LOCAL.

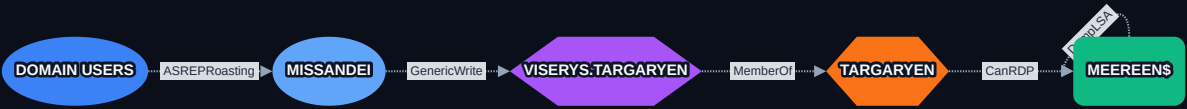
5. MEMBEROF

BRAAVOS\$@ESSOS.LOCAL is a direct or nested member of CERT PUBLISHERS@ESSOS.LOCAL. All privileges held by CERT PUBLISHERS@ESSOS.LOCAL — including any onward attack-path edges — are inherited by BRAAVOS\$@ESSOS.LOCAL.

○ DOMAIN COMPROMISED

CANONICAL TERMINUS — EVERY PATH ENDS HERE.

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach MEEREEN\$@ESSOS.LOCAL in 5 steps. The path chains ASREPROasting, GenericWrite, MemberOf, CanRDP, and DumpLSA. This attack path is a theoretical route derived from configuration analysis.



STEP-BY-STEP BREAKDOWN

1. ASREPROASTING

ASREPROasting targets accounts — in this path, MISSANDEI@ESSOS.LOCAL — that have Kerberos pre-authentication disabled (DONT_REQ_PREAUTH flag). Any unauthenticated attacker (including DOMAIN USERS@ESSOS.LOCAL) can request an AS-REP message encrypted with the account's password-derived key and crack it offline. Successful cracking yields full credentials for MISSANDEI@ESSOS.LOCAL.

2. GENERICWRITE

GenericWrite gives user MISSANDEI@ESSOS.LOCAL the ability to modify most attributes of user VISERY.S.TARGARYEN@ESSOS.LOCAL. Typical abuse paths include writing msDS-KeyCredentialLink (Shadow Credentials) to obtain a PKINIT certificate, setting a servicePrincipalName to enable Kerberoasting, or modifying scriptPath / msDS-AllowedToActOnBehalfOfOtherIdentity. Any of these leads to full compromise of VISERY.S.TARGARYEN@ESSOS.LOCAL.

3. MEMBEROF

VISERY.S.TARGARYEN@ESSOS.LOCAL is a direct or nested member of TARGARYEN@ESSOS.LOCAL. All privileges held by TARGARYEN@ESSOS.LOCAL — including any onward attack-path edges — are inherited by VISERY.S.TARGARYEN@ESSOS.LOCAL.

4. CANRDP

CanRDP: TARGARYEN@ESSOS.LOCAL can initiate an RDP session on MEEREEN\$@ESSOS.LOCAL. Remote Desktop access provides an interactive graphical session on the target machine. An attacker with RDP access can: extract credentials from memory (especially if a privileged user is already logged on); install persistence mechanisms; pivot to other network segments accessible from MEEREEN\$@ESSOS.LOCAL; or abuse services running in the session. RDP sessions generate logon event 4624 (type 10) and may be detectable via session recording if configured.

5. DUMPLSA

DumpLSA: Credential material extracted was validated for MEEREEN\$@ESSOS.LOCAL, confirming that post-compromise dump data exposed reusable secrets.

○ DOMAIN COMPROMISED

CANONICAL TERMINUS — EVERY PATH ENDS HERE.

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 5 steps. The path chains ASREPROasting, GenericWrite, ADCS ESC9, MemberOf, and DCSync. This attack path is a theoretical route derived from configuration analysis.



STEP-BY-STEP BREAKDOWN

1. ASREPROASTING

ASREPROasting targets accounts — in this path, MISSANDEI@ESSOS.LOCAL — that have Kerberos pre-authentication disabled (DONT_REQ_PREAUTH flag). Any unauthenticated attacker (including DOMAIN USERS@ESSOS.LOCAL) can request an AS-REP message encrypted with the account's password-derived key and crack it offline. Successful cracking yields full credentials for MISSANDEI@ESSOS.LOCAL.

2. GENERICWRITE

GenericWrite gives user MISSANDEI@ESSOS.LOCAL the ability to modify most attributes of user VISERY.S.TARGARYEN@ESSOS.LOCAL. Typical abuse paths include writing msDS-KeyCredentialLink (Shadow Credentials) to obtain a PKINIT certificate, setting a servicePrincipalName to enable Kerberoasting, or modifying scriptPath / msDS-AllowedToActOnBehalfOfOtherIdentity. Any of these leads to full compromise of VISERY.S.TARGARYEN@ESSOS.LOCAL.

3. ADCSESC9

ADCS ESC9: A certificate template accessible to VISERY.S.TARGARYEN@ESSOS.LOCAL is configured with CT_FLAG_NO_SECURITY_EXTENSION, omitting the szOID_NTDS_CA_SECURITY_EXT SID binding from issued certificates. Without this extension, certificate-to-account mapping relies on UPN matching rather than cryptographic SID identity. VISERY.S.TARGARYEN@ESSOS.LOCAL can temporarily modify a controlled account's UPN to match a privileged user's UPN, enroll for a certificate during that window, restore the original UPN, and then authenticate as the privileged user using the issued certificate. This bypasses KB5014754 strong mapping protections when the security extension is absent from the template.

4. MEMBEROF

DOMAIN ADMINS@ESSOS.LOCAL is a direct or nested member of ADMINISTRATORS@ESSOS.LOCAL. All privileges held by ADMINISTRATORS@ESSOS.LOCAL — including any onward attack-path edges — are inherited by DOMAIN ADMINS@ESSOS.LOCAL.

5. DCSYNC

ADMINISTRATORS@ESSOS.LOCAL holds the Replicating Directory Changes and Replicating Directory Changes All extended rights on the domain, meaning it can pull password hashes for any account via the DRSUAPI protocol (DCSync). Extracting the krbtgt hash yields persistent golden-ticket capability and full domain compromise.

○ DOMAIN COMPROMISED

CANONICAL TERMINUS — EVERY PATH ENDS HERE.

Starting from MISSANDEI@ESSOS.LOCAL, an attacker can reach JORAH.MORMONT@ESSOS.LOCAL in 2 steps. The path abuses GenericWrite. This attack path is a theoretical route derived from configuration analysis.



STEP-BY-STEP BREAKDOWN

1. GENERICWRITE

GenericWrite gives user MISSANDEI@ESSOS.LOCAL the ability to modify most attributes of user VISERY.S.TARGARYEN@ESSOS.LOCAL. Typical abuse paths include writing msDS-KeyCredentialLink (Shadow Credentials) to obtain a PKINIT certificate, setting a servicePrincipalName to enable Kerberoasting, or modifying scriptPath / msDS-AllowedToActOnBehalfOfOtherIdentity. Any of these leads to full compromise of VISERY.S.TARGARYEN@ESSOS.LOCAL.

2. GENERICWRITE

GenericWrite gives user VISERY.S.TARGARYEN@ESSOS.LOCAL the ability to modify most attributes of user JORAH.MORMONT@ESSOS.LOCAL. Typical abuse paths include writing msDS-KeyCredentialLink (Shadow Credentials) to obtain a PKINIT certificate, setting a servicePrincipalName to enable Kerberoasting, or modifying scriptPath / msDS-AllowedToActOnBehalfOfOtherIdentity. Any of these leads to full compromise of JORAH.MORMONT@ESSOS.LOCAL.

○ DOMAIN COMPROMISED

CANONICAL TERMINUS — EVERY PATH ENDS HERE.

Starting from MISSANDEI@ESSOS.LOCAL, an attacker can reach BRAAVOS\$@ESSOS.LOCAL in 5 steps. The path chains GenericAll, GenericWrite, ReadLAPSPassword, and DumpLSA. This attack path is a theoretical route derived from configuration analysis.



STEP-BY-STEP BREAKDOWN

1. GENERICALL

GenericAll grants user MISSANDEI@ESSOS.LOCAL full read and write control over user KHAL.DROGO@ESSOS.LOCAL. This allows the source to reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink), set a Service Principal Name to enable Kerberoasting, or write a logon script — any of which results in complete compromise of KHAL.DROGO@ESSOS.LOCAL.

2. GENERICALL

GenericAll grants user KHAL.DROGO@ESSOS.LOCAL full read and write control over user VISERYS.TARGARYEN@ESSOS.LOCAL. This allows the source to reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink), set a Service Principal Name to enable Kerberoasting, or write a logon script — any of which results in complete compromise of VISERYS.TARGARYEN@ESSOS.LOCAL.

3. GENERICWRITE

GenericWrite gives user VISERYS.TARGARYEN@ESSOS.LOCAL the ability to modify most attributes of user JORAH.MORMONT@ESSOS.LOCAL. Typical abuse paths include writing msDS-KeyCredentialLink (Shadow Credentials) to obtain a PKINIT certificate, setting a servicePrincipalName to enable Kerberoasting, or modifying scriptPath / msDS-AllowedToActOnBehalfOfOtherIdentity. Any of these leads to full compromise of JORAH.MORMONT@ESSOS.LOCAL.

4. READLAPSPASSWORD

The ReadLAPSPassword edge means JORAH.MORMONT@ESSOS.LOCAL has the Control Access right on the ms-Mcs-AdmPwd (or ms-LAPS-Password) attribute of BRAAVOS\$@ESSOS.LOCAL. JORAH.MORMONT@ESSOS.LOCAL simply queries the attribute via LDAP to retrieve the local Administrator password in cleartext and pivots to BRAAVOS\$@ESSOS.LOCAL.

5. DUMPLSA

DumpLSA: Credential material extracted was validated for BRAAVOS\$@ESSOS.LOCAL, confirming that post-compromise dump data exposed reusable secrets.

○ DOMAIN COMPROMISED

CANONICAL TERMINUS — EVERY PATH ENDS HERE.

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach CERT PUBLISHERS@ESSOS.LOCAL in 6 steps. The path chains ASREPROasting, GenericAll, GenericWrite, ReadLAPSPassword, and MemberOf. This attack path is a theoretical route derived from configuration analysis.



STEP-BY-STEP BREAKDOWN

1. ASREPROASTING

ASREPROasting targets accounts — in this path, MISSANDEI@ESSOS.LOCAL — that have Kerberos pre-authentication disabled (DONT_REQ_PREAUTH flag). Any unauthenticated attacker (including DOMAIN USERS@ESSOS.LOCAL) can request an AS-REP message encrypted with the account's password-derived key and crack it offline. Successful cracking yields full credentials for MISSANDEI@ESSOS.LOCAL.

2. GENERICALL

GenericAll grants user MISSANDEI@ESSOS.LOCAL full read and write control over user KHAL.DROGO@ESSOS.LOCAL. This allows the source to reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink), set a Service Principal Name to enable Kerberoasting, or write a logon script — any of which results in complete compromise of KHAL.DROGO@ESSOS.LOCAL.

3. GENERICALL

GenericAll grants user KHAL.DROGO@ESSOS.LOCAL full read and write control over user VISERYSTARGARYEN@ESSOS.LOCAL. This allows the source to reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink), set a Service Principal Name to enable Kerberoasting, or write a logon script — any of which results in complete compromise of VISERYSTARGARYEN@ESSOS.LOCAL.

4. GENERICWRITE

GenericWrite gives user VISERYSTARGARYEN@ESSOS.LOCAL the ability to modify most attributes of user JORAH.MORMONT@ESSOS.LOCAL. Typical abuse paths include writing msDS-KeyCredentialLink (Shadow Credentials) to obtain a PKINIT certificate, setting a servicePrincipalName to enable Kerberoasting, or modifying scriptPath / msDS-AllowedToActOnBehalfOfOtherIdentity. Any of these leads to full compromise of JORAH.MORMONT@ESSOS.LOCAL.

5. READLAPSPASSWORD

The ReadLAPSPassword edge means JORAH.MORMONT@ESSOS.LOCAL has the Control Access right on the ms-Mcs-AdmPwd (or ms-LAPS-Password) attribute of BRAAVOS\$@ESSOS.LOCAL. JORAH.MORMONT@ESSOS.LOCAL simply queries the attribute via LDAP to retrieve the local Administrator password in cleartext and pivots to BRAAVOS\$@ESSOS.LOCAL.

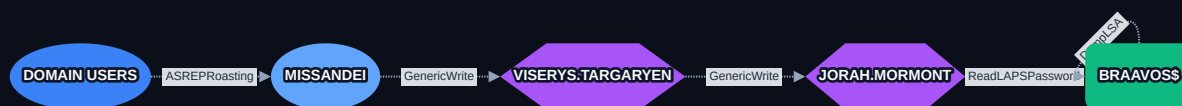
6. MEMBEROF

BRAAVOS\$@ESSOS.LOCAL is a direct or nested member of CERT PUBLISHERS@ESSOS.LOCAL. All privileges held by CERT PUBLISHERS@ESSOS.LOCAL — including any onward attack-path edges — are inherited by BRAAVOS\$@ESSOS.LOCAL.

○ DOMAIN COMPROMISED

CANONICAL TERMINUS — EVERY PATH ENDS HERE.

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach BRAAVOS\$@ESSOS.LOCAL in 5 steps. The path chains ASREPROasting, GenericWrite, ReadLAPSPassword, and DumpLSA. This attack path is a theoretical route derived from configuration analysis.



STEP-BY-STEP BREAKDOWN

1. ASREPROASTING

ASREPROasting targets accounts — in this path, MISSANDEI@ESSOS.LOCAL — that have Kerberos pre-authentication disabled (DONT_REQ_PREAUTH flag). Any unauthenticated attacker (including DOMAIN USERS@ESSOS.LOCAL) can request an AS-REP message encrypted with the account's password-derived key and crack it offline. Successful cracking yields full credentials for MISSANDEI@ESSOS.LOCAL.

2. GENERICWRITE

GenericWrite gives user MISSANDEI@ESSOS.LOCAL the ability to modify most attributes of user VISERYS.TARGARYEN@ESSOS.LOCAL. Typical abuse paths include writing msDS-KeyCredentialLink (Shadow Credentials) to obtain a PKINIT certificate, setting a servicePrincipalName to enable Kerberoasting, or modifying scriptPath / msDS-AllowedToActOnBehalfOfOtherIdentity. Any of these leads to full compromise of VISERYS.TARGARYEN@ESSOS.LOCAL.

3. GENERICWRITE

GenericWrite gives user VISERYS.TARGARYEN@ESSOS.LOCAL the ability to modify most attributes of user JORAH.MORMONT@ESSOS.LOCAL. Typical abuse paths include writing msDS-KeyCredentialLink (Shadow Credentials) to obtain a PKINIT certificate, setting a servicePrincipalName to enable Kerberoasting, or modifying scriptPath / msDS-AllowedToActOnBehalfOfOtherIdentity. Any of these leads to full compromise of JORAH.MORMONT@ESSOS.LOCAL.

4. READLAPSPASSWORD

The ReadLAPSPassword edge means JORAH.MORMONT@ESSOS.LOCAL has the Control Access right on the ms-Mcs-AdmPwd (or ms-LAPS-Password) attribute of BRAAVOS\$@ESSOS.LOCAL. JORAH.MORMONT@ESSOS.LOCAL simply queries the attribute via LDAP to retrieve the local Administrator password in cleartext and pivots to BRAAVOS\$@ESSOS.LOCAL.

5. DUMPLSA

DumpLSA: Credential material extracted was validated for BRAAVOS\$@ESSOS.LOCAL, confirming that post-compromise dump data exposed reusable secrets.

○ DOMAIN COMPROMISED

CANONICAL TERMINUS — EVERY PATH ENDS HERE.

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach MEEREEN\$@ESSOS.LOCAL in 6 steps. The path chains ASREPROasting, GenericAll, MemberOf, CanRDP, and DumpLSA. This attack path is a theoretical route derived from configuration analysis.



STEP-BY-STEP BREAKDOWN

1. ASREPROASTING

ASREPROasting targets accounts — in this path, MISSANDEI@ESSOS.LOCAL — that have Kerberos pre-authentication disabled (DONT_REQ_PREAUTH flag). Any unauthenticated attacker (including DOMAIN USERS@ESSOS.LOCAL) can request an AS-REP message encrypted with the account's password-derived key and crack it offline. Successful cracking yields full credentials for MISSANDEI@ESSOS.LOCAL.

2. GENERICALL

GenericAll grants user MISSANDEI@ESSOS.LOCAL full read and write control over user KHAL.DROGO@ESSOS.LOCAL. This allows the source to reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink), set a Service Principal Name to enable Kerberoasting, or write a logon script — any of which results in complete compromise of KHAL.DROGO@ESSOS.LOCAL.

3. GENERICALL

GenericAll grants user KHAL.DROGO@ESSOS.LOCAL full read and write control over user VISERY\$.TARGARYEN@ESSOS.LOCAL. This allows the source to reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink), set a Service Principal Name to enable Kerberoasting, or write a logon script — any of which results in complete compromise of VISERY\$.TARGARYEN@ESSOS.LOCAL.

4. MEMBEROF

VISERY\$.TARGARYEN@ESSOS.LOCAL is a direct or nested member of TARGARYEN@ESSOS.LOCAL. All privileges held by TARGARYEN@ESSOS.LOCAL — including any onward attack-path edges — are inherited by VISERY\$.TARGARYEN@ESSOS.LOCAL.

5. CANRDP

CanRDP: TARGARYEN@ESSOS.LOCAL can initiate an RDP session on MEEREEN\$@ESSOS.LOCAL. Remote Desktop access provides an interactive graphical session on the target machine. An attacker with RDP access can: extract credentials from memory (especially if a privileged user is already logged on); install persistence mechanisms; pivot to other network segments accessible from MEEREEN\$@ESSOS.LOCAL; or abuse services running in the session. RDP sessions generate logon event 4624 (type 10) and may be detectable via session recording if configured.

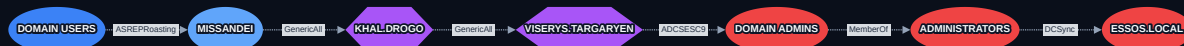
6. DUMPLSA

DumpLSA: Credential material extracted was validated for MEEREEN\$@ESSOS.LOCAL, confirming that post-compromise dump data exposed reusable secrets.

○ DOMAIN COMPROMISED

CANONICAL TERMINUS — EVERY PATH ENDS HERE.

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach ESSOS.LOCAL in 6 steps. The path chains ASREPROasting, GenericAll, ADCS ESC9, MemberOf, and DCSync. This attack path is a theoretical route derived from configuration analysis.



STEP-BY-STEP BREAKDOWN

1. ASREPROASTING

ASREPROasting targets accounts — in this path, MISSANDEI@ESSOS.LOCAL — that have Kerberos pre-authentication disabled (DONT_REQ_PREAUTH flag). Any unauthenticated attacker (including DOMAIN USERS@ESSOS.LOCAL) can request an AS-REP message encrypted with the account's password-derived key and crack it offline. Successful cracking yields full credentials for MISSANDEI@ESSOS.LOCAL.

2. GENERICALL

GenericAll grants user MISSANDEI@ESSOS.LOCAL full read and write control over user KHAL.DROGO@ESSOS.LOCAL. This allows the source to reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink), set a Service Principal Name to enable Kerberoasting, or write a logon script — any of which results in complete compromise of KHAL.DROGO@ESSOS.LOCAL.

3. GENERICALL

GenericAll grants user KHAL.DROGO@ESSOS.LOCAL full read and write control over user VISERYS.TARGARYEN@ESSOS.LOCAL. This allows the source to reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink), set a Service Principal Name to enable Kerberoasting, or write a logon script — any of which results in complete compromise of VISERYS.TARGARYEN@ESSOS.LOCAL.

4. ADCSESC9

ADCS ESC9: A certificate template accessible to VISERYS.TARGARYEN@ESSOS.LOCAL is configured with CT_FLAG_NO_SECURITY_EXTENSION, omitting the szOID_NTDS_CA_SECURITY_EXT SID binding from issued certificates. Without this extension, certificate-to-account mapping relies on UPN matching rather than cryptographic SID identity. VISERYS.TARGARYEN@ESSOS.LOCAL can temporarily modify a controlled account's UPN to match a privileged user's UPN, enroll for a certificate during that window, restore the original UPN, and then authenticate as the privileged user using the issued certificate. This bypasses KB5014754 strong mapping protections when the security extension is absent from the template.

5. MEMBEROF

DOMAIN ADMINS@ESSOS.LOCAL is a direct or nested member of ADMINISTRATORS@ESSOS.LOCAL. All privileges held by ADMINISTRATORS@ESSOS.LOCAL — including any onward attack-path edges — are inherited by DOMAIN ADMINS@ESSOS.LOCAL.

6. DCSYNC

ADMINISTRATORS@ESSOS.LOCAL holds the Replicating Directory Changes and Replicating Directory Changes All extended rights on the domain, meaning it can pull password hashes for any account via the DRSUAPI protocol (DCSync). Extracting the krbtgt hash yields persistent golden-ticket capability and full domain compromise.

Starting from DOMAIN USERS@ESSOS.LOCAL, an attacker can reach BRAAVOS\$@ESSOS.LOCAL in 6 steps. The path chains ASREProasting, GenericAll, GenericWrite, ReadLAPSPassword, and DumpLSA. This attack path is a theoretical route derived from configuration analysis.



STEP-BY-STEP BREAKDOWN

1. ASREPROASTING

ASREProasting targets accounts — in this path, MISSANDEI@ESSOS.LOCAL — that have Kerberos pre-authentication disabled (DONT_REQ_PREAUTH flag). Any unauthenticated attacker (including DOMAIN USERS@ESSOS.LOCAL) can request an AS-REP message encrypted with the account's password-derived key and crack it offline. Successful cracking yields full credentials for MISSANDEI@ESSOS.LOCAL.

2. GENERICALL

GenericAll grants user MISSANDEI@ESSOS.LOCAL full read and write control over user KHAL.DROGO@ESSOS.LOCAL. This allows the source to reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink), set a Service Principal Name to enable Kerberoasting, or write a logon script — any of which results in complete compromise of KHAL.DROGO@ESSOS.LOCAL.

3. GENERICALL

GenericAll grants user KHAL.DROGO@ESSOS.LOCAL full read and write control over user VISERY.S.TARGARYEN@ESSOS.LOCAL. This allows the source to reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink), set a Service Principal Name to enable Kerberoasting, or write a logon script — any of which results in complete compromise of VISERY.S.TARGARYEN@ESSOS.LOCAL.

4. GENERICWRITE

GenericWrite gives user VISERY.S.TARGARYEN@ESSOS.LOCAL the ability to modify most attributes of user JORAH.MORMONT@ESSOS.LOCAL. Typical abuse paths include writing msDS-KeyCredentialLink (Shadow Credentials) to obtain a PKINIT certificate, setting a servicePrincipalName to enable Kerberoasting, or modifying scriptPath / msDS-AllowedToActOnBehalfOfOtherIdentity. Any of these leads to full compromise of JORAH.MORMONT@ESSOS.LOCAL.

5. READLAPSPASSWORD

The ReadLAPSPassword edge means JORAH.MORMONT@ESSOS.LOCAL has the Control Access right on the ms-Mcs-AdmPwd (or ms-LAPS-Password) attribute of BRAAVOS\$@ESSOS.LOCAL. JORAH.MORMONT@ESSOS.LOCAL simply queries the attribute via LDAP to retrieve the local Administrator password in cleartext and pivots to BRAAVOS\$@ESSOS.LOCAL.

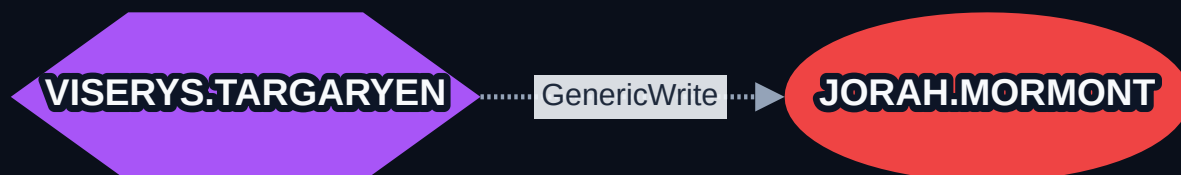
6. DUMPLSA

DumpLSA: Credential material extracted was validated for BRAAVOS\$@ESSOS.LOCAL, confirming that post-compromise dump data exposed reusable secrets.

○ DOMAIN COMPROMISED

CANONICAL TERMINUS — EVERY PATH ENDS HERE.

Starting from VISERY.S.TARGARYEN@ESSOS.LOCAL, an attacker can reach JORAH.MORMONT@ESSOS.LOCAL in 1 step. The path abuses GenericWrite. This attack path is a theoretical route derived from configuration analysis.



STEP-BY-STEP BREAKDOWN

1. GENERICWRITE

GenericWrite gives user VISERY.S.TARGARYEN@ESSOS.LOCAL the ability to modify most attributes of user JORAH.MORMONT@ESSOS.LOCAL. Typical abuse paths include writing msDS-KeyCredentialLink (Shadow Credentials) to obtain a PKINIT certificate, setting a servicePrincipalName to enable Kerberoasting, or modifying scriptPath / msDS-AllowedToActOnBehalfOfOtherIdentity. Any of these leads to full compromise of JORAH.MORMONT@ESSOS.LOCAL.

○ DOMAIN COMPROMISED

CANONICAL TERMINUS — EVERY PATH ENDS HERE.

Starting from KHAL.DROGO@ESSOS.LOCAL, an attacker can reach JORAH.MORMONT@ESSOS.LOCAL in 2 steps. The path chains GenericAll and GenericWrite. This attack path is a theoretical route derived from configuration analysis.



STEP-BY-STEP BREAKDOWN

1. GENERICALL

GenericAll grants user KHAL.DROGO@ESSOS.LOCAL full read and write control over user VISERY.S.TARGARYEN@ESSOS.LOCAL. This allows the source to reset the target's password, add Shadow Credentials (msDS-KeyCredentialLink), set a Service Principal Name to enable Kerberoasting, or write a logon script — any of which results in complete compromise of VISERY.S.TARGARYEN@ESSOS.LOCAL.

2. GENERICWRITE

GenericWrite gives user VISERY.S.TARGARYEN@ESSOS.LOCAL the ability to modify most attributes of user JORAH.MORMONT@ESSOS.LOCAL. Typical abuse paths include writing msDS-KeyCredentialLink (Shadow Credentials) to obtain a PKINIT certificate, setting a servicePrincipalName to enable Kerberoasting, or modifying scriptPath / msDS-AllowedToActOnBehalfOfOtherIdentity. Any of these leads to full compromise of JORAH.MORMONT@ESSOS.LOCAL.

○ DOMAIN COMPROMISED

CANONICAL TERMINUS — EVERY PATH ENDS HERE.

03 Technical Findings

Detailed vulnerability breakdown with remediation guidance.

ADSCAN SCORING METHODOLOGY

Three categories, two scores. Honest by design.

Each finding is classified into one of three categories — visible as a coloured badge — so the reader can separate *what kind of finding it is* from *how severe*:

• **VULNERABILITY** is a real exploit (formal CVSS Base applies); • **CHAIN PREREQUISITE** is a primitive that enables an attack chain (no CVSS Base — Critical only when the chain is confirmed); • **POSTURE** documents the absence of a control (hygiene gap, capped at High even on Tier-0).

Two scores are reported per finding. **CVSS Base** is the FIRST.org-aligned, environment-agnostic score for compliance and comparability. **ADscan Priority** overlays environmental signals observed in this assessment to surface what to fix first. When they differ, the finding was elevated by one of the conditions below.

Tier-0 exposure — affected principal or attack-path target is Domain Admin / KRBTGT / DC. **DC targeting** — at least one Domain Controller is in scope of the issue.

Relay confirmed — a vulnerable relay target (ADCS Web Enrollment without EPA, LDAP without signing/CB) was identified in this workspace.

Exploitation confirmed — concrete evidence captured (cracked hash, working PoC, full chain executed).

F-001

DCSync Privilege Abuse

CRITICAL

ADscan Priority **9.8 Critical**

CVSS Base 9.8

ACTIVE DIRECTORY

• **VULNERABILITY**

CWE-269 essos.local

CVSS 3.1 VECTOR CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

DESCRIPTION

The DCSync attack exploits Active Directory's directory replication protocol (MS-DRSR) to simulate the behavior of a Domain Controller requesting credential replication. Accounts holding the Replicating Directory Changes and Replicating Directory Changes All permissions — typically reserved for Domain Controllers and directory synchronisation services — can invoke the GetNCChanges RPC call to retrieve NTLM password hashes, Kerberos keys (AES-128, AES-256), and historical credentials for any domain account. The attack requires no local access to Domain Controllers and generates no authentication event on the target DC, making it extremely difficult to detect without dedicated tools. The KRBTGT account hash, in particular, enables Golden Ticket forgery that persists independently of all other credential rotations.

IMPACT

An attacker with DCSync capability can silently extract credentials for every privileged account in the domain, including Domain Admins, the KRBTGT account, and all service accounts. Possession of the KRBTGT hash enables Golden Ticket attacks that remain valid even after domain-wide password resets, providing persistent, undetectable access to the entire domain for up to 10 years without further exploitation.

AFFECTED ASSETS

- ESSOS.LOCAL

REMEDIATION

- Identify all principals with Replicating Directory Changes All permission using LDAP ACL enumeration and remove unnecessary grants
- Restrict replication rights to Domain Controllers and authorised sync accounts only (e.g., Azure AD Connect, specific backup solutions)
- Enable audit logging for directory service replication events (Event ID 4662) and alert on replication requests from non-DC hosts
- Rotate the KRBTGT password twice to invalidate any Golden Tickets that may have been issued before remediation

F-002

ADCS ESC9 - No Security Extension on Certificate Template

HIGH

ADscan Priority 8.5 High

CVSS Base 8.5

ADCS

VULNERABILITY

CWE-269 essos.local

METHODOLOGY Posture finding — measured by ADscan methodology (no CVSS Base applies).

DESCRIPTION

ADCS ESC9 exploits the CT_FLAG_NO_SECURITY_EXTENSION flag on a certificate template. When this flag is set, the szOID_NTDS_CA_SECURITY_EXT extension — which embeds the requester's SID into the issued certificate — is omitted. Without this SID binding, certificate-to-account mapping relies on UPN matching rather than strong SID-based identity verification. An attacker with GenericWrite access to an account that can enroll in the affected template can modify that account's UPN to match a high-privilege target (e.g., a Domain Admin UPN), obtain a certificate during that window, restore the UPN, and then use the issued certificate to authenticate as the target user. This technique bypasses the KB5014754 strong mapping protections when the security extension is absent.

IMPACT

Attackers can impersonate arbitrary domain users by temporarily manipulating UPN attributes on controllable accounts. The absence of the security extension means certificates cannot be reliably bound to their true issuance context, enabling persistent authentication bypass for accounts with enrollment access.

AFFECTED ASSETS

- SPYS@ESSOS.LOCAL
- DOMAIN_ADMINS@ESSOS.LOCAL
- ACCOUNT_OPERATORS@ESSOS.LOCAL
- KHAL.DROGO@ESSOS.LOCAL
- MISSANDEI@ESSOS.LOCAL
- VISERYS.TARGARYEN@ESSOS.LOCAL

REMEDIATION

- Remove the CT_FLAG_NO_SECURITY_EXTENSION flag from affected templates
- Enforce strong certificate mapping by applying KB5014754 and configuring the CertificateMappingMethods registry key
- Restrict write access to user UPN attributes to authorised administrators only

F-003

ADCS ESC14 - Weak Explicit Certificate Mapping Abuse

HIGH

ADscan Priority 8.5 High

CVSS Base 8.5

ADCS

VULNERABILITY

CWE-290 essos.local

METHODOLOGY Posture finding — measured by ADscan methodology (no CVSS Base applies).

DESCRIPTION

ADCS ESC14 abuses weak explicit certificate mappings configured through the altSecurityIdentities attribute. When administrators or applications rely on explicit mappings that are not strongly bound to the certificate holder's SID, an attacker who can enroll or obtain a suitable certificate can craft a cert that matches the weak mapping format and authenticate as the mapped account. This bypasses the intended identity binding guarantees of certificate-based authentication and can expose privileged accounts if they are explicitly mapped.

IMPACT

A weak explicit mapping can turn certificate enrollment or certificate theft into immediate privileged impersonation. If the mapped account is an admin, the attacker can authenticate directly as that identity and operate with the same rights as the victim without knowing the victim's password.

AFFECTED ASSETS

- ENTERPRISE READ-ONLY DOMAIN CONTROLLERS@ESSOS.LOCAL
- KERBEROS AUTHENTICATION@ESSOS.LOCAL

REMEDIATION

- Audit altSecurityIdentities mappings and remove weak or legacy mapping formats that do not enforce strong identity binding
- Prefer strong certificate mappings that rely on the SID security extension and enforce KB5014754 Full enforcement mode on domain controllers
- Restrict enrollment rights on templates that could mint certificates usable against explicitly mapped privileged accounts

F-004

ADCS ESC1 - Misconfigured Certificate Template

HIGH

ADscan Priority 8.5 High

CVSS Base 8.5

ADCS

VULNERABILITY

CWE-269 essos.local

METHODOLOGY Posture finding — measured by ADscan methodology (no CVSS Base applies).

DESCRIPTION

ADCS ESC1 occurs when a certificate template is configured to allow requesters to specify a Subject Alternative Name (SAN) in their certificate request, combined with an authentication-capable Extended Key Usage (EKU) such as Client Authentication, Smart Card Logon, or PKINIT. Any principal with enroll permissions on such a template can request a certificate asserting the identity of any user in the domain, including Domain Administrators, by specifying their UPN in the SAN field. Active Directory validates Kerberos authentication based on the certificate SAN rather than the requesting identity, allowing the attacker to obtain a TGT for the impersonated user without knowledge of their password.

IMPACT

Any domain user with enrollment rights on the template can obtain a certificate impersonating a Domain Administrator and authenticate to any Kerberos-capable service with full DA privileges. The resulting access bypasses password rotation, MFA tied to passwords, and most authentication monitoring, as the action uses a legitimately issued certificate.

AFFECTED ASSETS

- DOMAIN USERS@ESSOS.LOCAL
- DOMAIN ADMINS@ESSOS.LOCAL

REMEDIATION

- Disable the 'Supply in the request' option for Subject Name in the affected template (set to 'Build from Active Directory information')
- Review and restrict enrollment permissions to only the principals that legitimately require certificate enrollment
- Remove authentication EKUs (Client Authentication, Smart Card Logon) from templates that do not require them
- Enable CA Manager Approval for sensitive templates as an additional control layer

F-005

ADCS ESC13 - Issuance Policy with Group Link Abuse

HIGH

ADscan Priority 8.5 High

CVSS Base 8.5

ADCS

VULNERABILITY

CWE-269 essos.local

METHODOLOGY Posture finding — measured by ADscan methodology (no CVSS Base applies).

DESCRIPTION

ADCS ESC13 exploits certificate templates that have an Issuance Policy OID linked to an Active Directory group via the msDS-OIDToGroupLink attribute. When a user is issued a certificate based on such a template, the certificate includes the linked OID, and during Kerberos authentication the KDC automatically adds the linked group's SID to the resulting ticket. If the linked group is a privileged group such as Domain Admins or Enterprise Admins, any user who can enroll in the template is effectively granted membership in that privileged group for the duration of their certificate's validity — without being an actual member of the group in Active Directory.

IMPACT

Enrollment in an ESC13-affected template may grant temporary but fully functional membership in privileged groups such as Domain Admins. An attacker can enroll, use the resulting elevated Kerberos ticket to perform administrative actions including DCSync, and the privilege grant is entirely derived from certificate policy rather than group membership, making it difficult to detect through standard group membership auditing.

AFFECTED ASSETS

- DOMAIN USERS@ESSOS.LOCAL
- ESC13@ESSOS.LOCAL

REMEDIATION

- Audit all Issuance Policy OIDs linked to groups via msDS-OIDToGroupLink and assess whether the linked groups are appropriate
- Restrict enrollment permissions on affected templates to only the principals for whom the elevated group membership is intended
- Remove OID-to-group links that grant membership in privileged groups unless operationally required and strictly controlled

F-006

ADCS ESC2 - Any Purpose Certificate Template

HIGH

ADscan Priority 8.5 High

CVSS Base 8.5

ADCS

VULNERABILITY

CWE-269 essos.local

METHODOLOGY Posture finding — measured by ADscan methodology (no CVSS Base applies).

DESCRIPTION

ADCS ESC2 occurs when a certificate template is configured with the Any Purpose ECU or with no ECU at all. A certificate with Any Purpose ECU is valid for all certificate usages including client authentication, code signing, server authentication, and email encryption. Combined with low-privilege enrollment rights, this allows an attacker to obtain a certificate that can be used to authenticate as the enrolling user against any Kerberos-capable service. Unlike ESC1, the certificate is issued with the requester's own identity, but the Any Purpose ECU makes the resulting certificate a powerful credential for lateral movement and service access that typically bypasses certificate-based access controls.

IMPACT

Attackers can obtain a maximally privileged certificate with their own identity that can be used for authentication, code signing, and other sensitive operations. Combined with ESC3 (enrollment agent), an ESC2 certificate can be leveraged to request certificates on behalf of other users, effectively bridging to ESC1-class exploitation.

AFFECTED ASSETS

- DOMAIN USERS@ESSOS.LOCAL
- DOMAIN ADMINS@ESSOS.LOCAL

REMEDIATION

- Remove the Any Purpose ECU from affected templates and restrict to only the specific ECUs required for the intended use case
- Add explicit ECUs that limit certificate usage scope
- Restrict enrollment permissions to only the principals that legitimately need this certificate type

F-007

ADCS ESC3 - Enrollment Agent Template Abuse

HIGH

ADscan Priority 8.5 High

CVSS Base 8.5

ADCS

VULNERABILITY

CWE-269 essos.local

METHODOLOGY Posture finding — measured by ADscan methodology (no CVSS Base applies).

DESCRIPTION

ADCS ESC3 exploits the Certificate Request Agent ECU, which enables a principal to request certificates on behalf of other users. When a template with the Certificate Request Agent ECU is accessible to low-privilege users, an attacker can enroll to obtain an enrollment agent certificate. Using this agent certificate, the attacker can then request certificates on behalf of any domain user — including Domain Administrators — against a second template that permits agent enrollment. This two-step abuse chain allows complete identity impersonation without requiring knowledge of the target user's credentials or any direct interaction with them.

IMPACT

An attacker can impersonate any domain user, including Domain Administrators, through a legitimate two-stage certificate issuance chain. The resulting certificate provides full authentication capability as the impersonated user against all Kerberos-enabled services in the domain.

AFFECTED ASSETS

- DOMAIN USERS@ESSOS.LOCAL
- DOMAIN ADMINS@ESSOS.LOCAL

REMEDIATION

- Restrict the enrollment agent template to only authorised Certificate Managers and enrollment agent accounts
- Configure Enrollment Agent Restrictions on the CA to limit which templates and subjects enrollment agents can request on behalf of others
- Audit all principals with enrollment rights on templates with the Certificate Request Agent ECU

F-008

ADCS ESC5 - Vulnerable CA Object ACL

HIGH

ADscan Priority **8.5** High

CVSS Base 8.5

ADCS

● VULNERABILITY

CWE-269 essos.local

METHODOLOGY Posture finding — measured by ADscan methodology (no CVSS Base applies).

DESCRIPTION

ADCS ESC5 involves misconfigured access controls on CA-level objects in Active Directory beyond certificate templates — including the CA server computer object, the CA object in the NTAuthCertificates store, the Enrollment Services container, and RPC/DCOM interfaces. When non-privileged principals hold write access to these objects, they can manipulate the CA infrastructure itself. Attacks may include modifying the CA computer object to enable RBCD-based impersonation, altering the NTAuthCertificates store, or exploiting delegated CA management permissions to issue fraudulent certificates directly.

IMPACT

Compromise of CA-level objects can undermine the entire PKI trust infrastructure for the domain. An attacker may be able to issue certificates for arbitrary identities, modify CA policy, or compromise the CA server itself, resulting in complete and persistent domain compromise that survives standard remediation procedures.

AFFECTED ASSETS

- BRAAVOSS@ESSOS.LOCAL
- DOMAIN ADMIN@ESSOS.LOCAL

REMEDIATION

- Audit ACLs on the CA computer object, Certification Authority object, and the NTAuthCertificates container in AD
- Restrict write access to CA infrastructure objects to only PKI administrators and Enterprise Admins
- Conduct a full PKI health review to identify additional CA-level exposure

F-009

ADCS ESC7 - Certificate Authority Privilege Abuse

HIGH

ADscan Priority 8.5 High

CVSS Base 8.5

ADCS

VULNERABILITY

CWE-269 essos.local

METHODOLOGY Posture finding — measured by ADscan methodology (no CVSS Base applies).

DESCRIPTION

ADCS ESC7 occurs when non-privileged users hold the Manage CA or Manage Certificates permissions on a Certificate Authority. The Manage CA right grants control over CA configuration and security settings, including the ability to enable the EDITF_ATTRIBUTESUBJECTALTNAME2 flag (ESC6), modify CA ACLs, and add certificate officers. The Manage Certificates right allows approval of pending certificate requests, including those that were submitted with a fraudulent SAN. An attacker with Manage Certificates can submit a certificate request for a privileged user's identity, set it to a pending state requiring approval, and then approve it themselves using their own management permission.

IMPACT

CA management rights provide near-complete control over the PKI trust infrastructure. An attacker can issue certificates for Domain Admins, modify CA policy to introduce persistent vulnerabilities, or manipulate certificate lifecycle in ways that enable persistent authentication bypass across the domain.

AFFECTED ASSETS

- BRAAVOSS@ESSOS.LOCAL
- DOMAIN_ADMINS@ESSOS.LOCAL

REMEDIATION

- Restrict Manage CA and Manage Certificates permissions to only authorised PKI administrators
- Enforce separation of duties: the same account should not hold both Manage CA and Manage Certificates permissions
- Regularly audit CA permission assignments using certutil -cainfo or the CA management MMC

F-010

ADCS ESC4 - Vulnerable Certificate Template ACL

HIGH

ADscan Priority 8.5 High

CVSS Base 8.5

ADCS

VULNERABILITY

CWE-269 essos.local

METHODOLOGY Posture finding — measured by ADscan methodology (no CVSS Base applies).

DESCRIPTION

ADCS ESC4 occurs when non-privileged principals hold write permissions (WriteProperty, WriteDACL, WriteOwner, or GenericWrite) on a certificate template object in Active Directory. Certificate template objects are stored in the Configuration naming context and are subject to standard AD ACL controls. With template modification rights, an attacker can alter the template configuration to introduce ESC1-class vulnerabilities — enabling SAN specification, removing EKU restrictions, or disabling manager approval — obtain a fraudulent certificate, and then optionally revert the changes to avoid detection. This technique escalates an otherwise safe template into an exploitable one without leaving persistent misconfiguration evidence.

IMPACT

An attacker with write access to any template can temporarily transform it into an ESC1-exploitable template, obtain a certificate impersonating a Domain Administrator, then revert the change. The window of exploitation is brief and may not trigger template misconfiguration monitoring, making this a stealthy path to domain compromise.

AFFECTED ASSETS

- KHAL.DROGO@ESSOS.LOCAL
- DOMAIN ADMIN@ESSOS.LOCAL

REMEDIATION

- Audit ACLs on all certificate template objects in the Configuration naming context and remove unnecessary write permissions from non-admin principals
- Ensure only Enterprise Admins, Domain Admins, and PKI administrators hold write permissions on template objects
- Enable auditing on template object modifications to detect unauthorised changes

F-011

ADCS ESC8 - NTLM Relay to Web Enrollment

HIGH

ADscan Priority 8.2 High CVSS Base 8.2 ADCS VULNERABILITY

CWE-306 essos.local

METHODOLOGY Posture finding — measured by ADscan methodology (no CVSS Base applies).

DESCRIPTION

ADCS ESC8 exploits the HTTP-based Certificate Enrollment web interface (certsrv) when NTLM authentication is permitted on the endpoint. An attacker who can coerce outbound NTLM authentication from a privileged host — such as a Domain Controller — using techniques including PetitPotam, PrinterBug, or DFSCoerce can relay that authentication to the CA web enrollment interface. The relayed NTLM session authenticates as the coerced host's machine account and requests a Domain Controller certificate. This DC certificate can then be used in a Pass-the-Certificate attack to request a Kerberos TGT as the DC machine account, enabling DCSync and full domain credential extraction.

IMPACT

Successful ESC8 exploitation against a Domain Controller certificate template enables full domain compromise through a DCSync attack, without requiring any initial privileged access. The attack chain — coerce DC authentication, relay to web enrollment, obtain DC certificate, DCSync — can be executed in minutes from a standard domain user account.

AFFECTED ASSETS

- DOMAIN USERS@ESSOS.LOCAL
- DOMAIN CONTROLLERS@ESSOS.LOCAL

REMEDIATION

- Enable Extended Protection for Authentication (EPA) on the Certificate Enrollment web service to prevent NTLM relay
- Require HTTPS with certificate-based mutual authentication for web enrollment endpoints
- Disable HTTP-based web enrollment if it is not operationally required and use alternative enrollment mechanisms
- Mitigate coercion attack vectors: apply PetitPotam patches, disable Print Spooler on DCs, and block RPC coercion paths

F-012

Domain Admin Sessions on Non-Privileged Hosts

HIGH

ADscan Priority 8.0 High

CVSS Base 8.0

PRIVILEGE

VULNERABILITY

CWE-269 essos.local

METHODOLOGY Posture finding — measured by ADscan methodology (no CVSS Base applies).

DESCRIPTION

Domain Administrator sessions were discovered on workstations, member servers, or other non-Tier 0 hosts. When a Domain Admin authenticates to a non-privileged system, their credentials — in the form of NTLM hashes, Kerberos TGTs, and potentially cleartext credentials — are loaded into the LSASS process memory of that host and may also be cached in the Windows Credential Manager. An attacker who compromises any such endpoint through phishing, vulnerability exploitation, or lateral movement can harvest these credentials using tools such as Mimikatz or ProcDump without triggering any domain-level security events. The exposure window lasts for the duration of the session and, in the case of cached credentials, potentially indefinitely.

IMPACT

Compromise of any host where a Domain Admin has an active or cached session provides full domain administrative credentials without requiring any additional exploitation. This collapses the security boundary between workstations and the domain tier, meaning a single phishing email or workstation-level vulnerability is sufficient for full domain takeover.

AFFECTED ASSETS

- ADSCAN@ESSOS.LOCAL

REMEDIATION

- Implement a tiered administrative model: Domain Admins should only authenticate to Tier 0 assets (Domain Controllers, PKI servers). Never log in to workstations or standard servers with DA credentials
- Use Privileged Access Workstations (PAWs) for all Domain Admin activity and restrict DA account logon rights via Group Policy
- Enable the Protected Users security group for all Domain Admin accounts to prevent credential caching and delegation
- Audit logon events for Domain Admin accounts on non-DC assets and alert on any non-compliant logon

F-013

gMSA Password Readable by Non-Admins

HIGH

ADscan Priority 7.5 High

CVSS Base 7.5

GMSA

VULNERABILITY

CWE-522 essos.local

CVSS 3.1 VECTOR CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

DESCRIPTION

Group Managed Service Accounts (gMSA) are a special account type in Active Directory that provides automatic password management for service accounts. The password is stored in the msDS-ManagedPassword attribute of the gMSA object and is only readable by principals listed in the msDS-GroupMSAMembership attribute. When this access control list is misconfigured to include non-privileged groups or overly broad membership, any member can retrieve the gMSA password blob using the DSGetPassword API. The password is returned as an MSDS-MANAGEDPASSWORD_BLOB structure that can be parsed to extract the current NT hash, enabling Pass-the-Hash attacks or Kerberos ticket requests using the gMSA's identity.

IMPACT

Compromise of a gMSA password provides full impersonation of the service account, including all associated service permissions, SPN-based access, and any delegated rights. Service accounts typically have privileged access to databases, web services, backup systems, and other critical infrastructure, making this a high-impact finding depending on the gMSA's configured permissions.

AFFECTED ASSETS

- GMSADRAGON\$@ESSOS.LOCAL

REMEDIATION

- Review the msDS-GroupMSAMembership attribute for all gMSAs and restrict access to only the hosts and service identities that require it
- Remove any user accounts or broad groups from gMSA membership lists
- Audit gMSA password retrieval events where possible
- Review the permissions associated with each gMSA to assess the impact of any potential compromise

F-014

LAPS Password Readable by Non-Admins

HIGH



ADscan Priority 7.5 High

CVSS Base 7.5

LAPS

VULNERABILITY

CWE-522 essos.local

CVSS 3.1 VECTOR CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

DESCRIPTION

The Local Administrator Password Solution (LAPS) stores per-machine local administrator credentials in the ms-Mcs-AdmPwd attribute of computer objects in Active Directory. By design, only designated administrative groups should have read access to this attribute. When the ACL on computer objects grants read access to non-privileged accounts — such as broad user groups, domain users, or helpdesk tiers — any member of those groups can query the attribute and retrieve the current plaintext local administrator password for any LAPS-managed machine. This misconfiguration is commonly introduced during LAPS deployment when access delegation is overly permissive.

IMPACT

Non-privileged users can retrieve local administrator passwords for any LAPS-managed machine in the affected OUs. This enables lateral movement to those machines with full local administrative rights, bypassing the security benefit that LAPS was deployed to provide. In environments where local administrator accounts have network access, this can escalate rapidly.

AFFECTED ASSETS

- BRAAVOSS@ESSOS.LOCAL

REMEDIATION

- Restrict read permissions on the ms-Mcs-AdmPwd and msLAPS-Password attributes to authorised administrator groups only
- Review all OU-level ACL delegations that affect computer objects and remove unnecessary LAPS attribute read access
- Rotate all LAPS passwords immediately to invalidate any passwords that may have been retrieved
- Implement monitoring for LAPS attribute read events in the Security event log

F-015

SMBv1 Protocol Enabled

HIGH

ADscan Priority **7.5 High**

CVSS Base 7.5

NETWORK SECURITY

• VULNERABILITY

CWE-1104 `essos.local`METHODOLOGY *Posture finding — measured by ADscan methodology (no CVSS Base applies).*

DESCRIPTION

One or more hosts respond to SMBv1 (NT LM 0.12) negotiate requests. SMBv1 is a legacy protocol deprecated by Microsoft since 2014. It lacks modern security features (encryption, secure negotiate, pre-auth integrity) and is directly exploited by EternalBlue (MS17-010), EternalRomance, and related NSA-derived tools that enabled WannaCry and NotPetya ransomware. Microsoft has disabled SMBv1 by default since Windows 10 1709.

IMPACT

Hosts with SMBv1 enabled are vulnerable to EternalBlue (MS17-010) and related exploits if unpatched, and remain exposed to SMBv1-specific attack primitives (NTLM downgrade, signing bypass) regardless of patch status. Domain Controllers with SMBv1 represent a critical exposure.

AFFECTED ASSETS

- `essos.local`

REMEDIATION

- Disable SMBv1: Set-SmbServerConfiguration -EnableSMB1Protocol \$false
- Verify via GPO: Computer Config → Admin Templates → Network → Lanman Workstation
- Check for legacy dependencies before disabling (XP clients, old NAS devices)
- Confirm MS17-010 patch is applied: KB4012212 (Win7/2008) or KB4012215+
- Monitor for SMBv1 negotiate attempts in Windows Event Log (Event ID 3000)

F-016

AS-REP Roasting

MEDIUM



ADscan Priority 6.9 Medium

CVSS Base 6.9

KERBEROS

VULNERABILITY

CWE-522 essos.local

CVSS 3.1 VECTOR CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

DESCRIPTION

Preauthentication offers protection against offline Password Cracking. When enabled, a user requesting access to a resource initiates communication with the Domain Controller (DC) by sending an Authentication Server Request (AS-REQ) message with a timestamp that is encrypted with the hash of their password. If and only if the DC is able to successfully decrypt the timestamp with the hash of the user's password, it will then send an Authentication Server Response (AS-REP) message that contains the Ticket Granting Ticket (TGT) to the user. Part of the AS-REP message is signed with the user's password. For each account found without preauthentication, an adversary may send an AS-REQ message without the encrypted timestamp and receive an AS-REP message with TGT data which may be encrypted with an insecure algorithm such as RC4. The recovered encrypted data may be vulnerable to offline Password Cracking attacks similarly to Kerberoasting and expose plaintext credentials.

IMPACT

A successful AS-REP Roasting attack along with cracked passwords could lead to lateral movement and privilege escalation in an AD environment. If a password is cracked for a Domain Administrator account or equivalent, an attacker could gain control over most, if not all, resources in the domain.

AFFECTED ASSETS

- MISSANDEI@ESSOS.LOCAL

REMEDIATION

Kerberos preauthentication is enabled by default. Older protocols might not support preauthentication therefore it is possible to have this setting disabled. Make sure that all accounts have preauthentication whenever possible and if it is not possible the following steps will help mitigate the risk of this attack:

- Enable AES Kerberos encryption instead of RC4
- Use strong 25+ character passwords for these accounts and rotate them periodically

F-017

All Extended Rights Assigned

MEDIUM

ADscan Priority 6.5 Medium

CVSS Base 6.5

PERMISSIONS

VULNERABILITY

CWE-284 essos.local

METHODOLOGY Posture finding — measured by ADscan methodology (no CVSS Base applies).

DESCRIPTION

The AllExtendedRights ACE grants a principal the ability to perform all extended operations on an Active Directory object in a single permission grant. For user objects, AllExtendedRights encompasses the User-Force-Change-Password right, the ability to read confidential attributes such as LAPS passwords and BitLocker recovery keys, and all other extended operations defined on the object class. This broad permission frequently results from overly permissive ACL delegation during AD administrative setup, Help Desk delegation, or legacy configuration that was never scoped down. The actual exploitability depends on the target object type, but the combination of rights included under AllExtendedRights generally exceeds any legitimate delegation requirement.

IMPACT

Depending on the target object, AllExtendedRights may allow password resets, access to confidential attributes, modification of security-sensitive properties, or other privileged operations. When present on high-value targets such as Domain Admin accounts or service accounts with elevated permissions, this represents a direct privilege escalation path.

AFFECTED ASSETS

- COMPU240\$@ESSOS.LOCAL

REMEDIATION

- Enumerate all AllExtendedRights ACEs using AD ACL auditing tools and replace them with specific, scoped permissions matching the legitimate operational requirement
- Apply the principle of least privilege — grant only the specific extended rights that are actually needed (e.g., User-Force-Change-Password only, not AllExtendedRights)
- Prioritise remediation on privileged accounts and service accounts that are members of sensitive groups

F-018

Kerberoasting

MEDIUM

ADscan Priority **5.3** Medium

CVSS Base 5.3

KERBEROS

VULNERABILITY

CWE-522 essos.local

CVSS 3.1 VECTOR CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

DESCRIPTION

In an Active Directory (AD) environment, Service Principal Names (SPNs) are used to uniquely identify instances of a Windows service. Kerberos authentication requires that each SPN be associated with one service account (Active Directory user account). Any authenticated AD user can request one or more Kerberos Ticket-Granting Service (TGS) tickets from the domain controller for any SPN accounts. These tickets are encrypted with the associated AD account's NTLM password hash. They can be brute forced offline using a password cracking tool such as Hashcat if a weak password is used along with the RC4 encryption algorithm. If AES encryption is in use, it will take more resources to crack a ticket to reveal the account's clear-text password, but it is possible if weak passwords are in use.

IMPACT

A successful Kerberoasting attack along with cracked passwords could lead to lateral movement and privilege escalation in an AD environment. If a password is cracked for a Domain Administrator account or equivalent, an attacker could gain control over most, if not all, resources in the domain.

AFFECTED ASSETS

- GMSADRAGON\$@ESSOS.LOCAL
- SQL_SVC@ESSOS.LOCAL

REMEDIATION

Where possible eliminate SPNs in the environment in favor of Group Managed Service Accounts (gMSA) which are not subject to this type of attack. If migration to gMSAs is not possible the following steps will help mitigate the risk of this attack:

- Enable AES Kerberos encryption instead of RC4
- Use strong 25+ character passwords for service accounts and rotate them periodically
- Limit the privileges of service accounts and avoid creating SPNs tied to highly privileged accounts such as Domain Administrators

F-019

SMB Signing Not Required

MEDIUM

ADscan Priority 5.0 Medium

CVSS Base 5.0

NETWORK SECURITY

• POSTURE

CWE-300 essos.local

METHODOLOGY Posture finding — measured by ADscan methodology (no CVSS Base applies).

DESCRIPTION

One or more domain-joined computers do not require SMB packet signing. When SMB signing is not enforced, an attacker in a man-in-the-middle position can relay NTLM authentication from these hosts to other services (NTLMrelay, Responder), authenticate as the relayed identity, and potentially execute code or access resources without knowing the credential.

IMPACT

Hosts with SMB signing disabled are viable relay targets. If the relayed credential belongs to a Domain Admin or computer account with unconstrained delegation, a single intercepted authentication can lead to full domain compromise. Domain Controllers with signing disabled are particularly severe as they represent the highest-value relay target in the environment.

AFFECTED ASSETS

- essos.local

REMEDIATION

- Set 'Microsoft network server: Digitally sign communications (always)' via GPO
- Set 'Microsoft network client: Digitally sign communications (always)' via GPO
- Prioritise Domain Controllers — enforce immediately
- Validate with: `nmap --script smb-security-mode` or `netexec smb <range>`
- Monitor for SMB relay attempts via Event ID 4624 from unexpected sources

Accounts with Non-Expiring Passwords

LOW

ADscan Priority **3.7** Low

CVSS Base 3.7

POLICY

• POSTURE

CWE-521 `essos.local`METHODOLOGY *Posture finding — measured by ADscan methodology (no CVSS Base applies).*

DESCRIPTION

Accounts configured with the `DONT_EXPIRE_PASSWORD` flag are exempt from the domain's password expiration policy, meaning their credentials remain valid indefinitely unless manually changed. While this configuration is sometimes necessary for service accounts running as specific identities, it is frequently applied broadly to user accounts for convenience, or inherited from legacy configurations. Long-lived credentials are statistically more likely to have been exposed through phishing, credential dumping incidents, data breaches, or pass-the-hash attacks that were not detected at the time. An attacker in possession of a non-expiring credential retains access indefinitely unless the compromise is specifically identified and the password is manually rotated.

IMPACT

Compromised non-expiring credentials provide persistent access with no natural remediation deadline. In environments where password rotation is the primary credential invalidation mechanism, these accounts create permanent persistence opportunities for attackers who have obtained the credentials through any means.

AFFECTED ASSETS

- `essos.local`

REMEDIATION

- Review all accounts with `DONT_EXPIRE_PASSWORD` set and determine whether the business justification remains valid
- Remove the flag from all standard user accounts and enforce domain password policy expiration
- For service accounts requiring static passwords, implement a documented manual rotation schedule with at least annual frequency
- Where possible, migrate service accounts to Group Managed Service Accounts (gMSA) which have automated password rotation

F-021

Machine Account Quota Allows Domain Join

LOW

ADscan Priority **3.5** Low

CVSS Base 3.5

DOMAIN CONFIGURATION

POSTURE

CWE-284 essos.local

METHODOLOGY Posture finding — measured by ADscan methodology (no CVSS Base applies).

DESCRIPTION

The ms-DS-MachineAccountQuota attribute is set to a value greater than 0. This allows any authenticated domain user to join computers to the domain up to the configured limit, which can be abused for RBCD attacks, DNS poisoning via fake computer objects, or Kerberos relay attack preparation.

IMPACT

An attacker with any valid domain credential can create computer objects under their control, enabling Resource-Based Constrained Delegation (RBCD) attacks, Kerberos relay setups (e.g. noPac), and persistence via machine accounts.

AFFECTED ASSETS

- essos.local

REMEDIATION

Set ms-DS-MachineAccountQuota to 0 via ADSI Edit or PowerShell (Set-ADDomain -Identity <domain> -Replace @{ms-DS-MachineAccountQuota='0'}).

Delegate computer join rights only to specific OUs and specific accounts.

F-022

Passwords Predating Current Policy

LOW



ADscan Priority **3.5** Low CVSS Base 3.5 IDENTITY HYGIENE POSTURE

CWE-521 essos.local

METHODOLOGY Posture finding — measured by ADscan methodology (no CVSS Base applies).

DESCRIPTION

One or more enabled user accounts have a password that was last set before the most recent modification to the applicable password policy (Default Domain Policy or a Fine-Grained PSO). The current policy requirements — minimum length, complexity, or maximum age — were not in effect when the credential was created. Active Directory does not retroactively force a reset on policy changes, so these accounts may carry credentials that do not comply with the organisation's current security baseline.

IMPACT

Credentials established under a weaker policy may be shorter, simpler, or older than the current standard allows. Attackers obtaining these hashes through LDAP, Kerberoasting, or credential dumping face a reduced cracking workload. When affected accounts are Tier-0 or high-value identities, the impact escalates to potential domain compromise.

AFFECTED ASSETS

- essos.local

REMEDIATION

- Identify all accounts whose pwdLastSet predates the policy's last modification
- Force an immediate reset for Tier-0, Domain Admin, and service accounts first
- Notify remaining affected users and enforce rotation within a defined window
- Consider enabling the 'User must change password at next logon' flag for bulk resets
- Schedule periodic policy-compliance audits after future policy changes

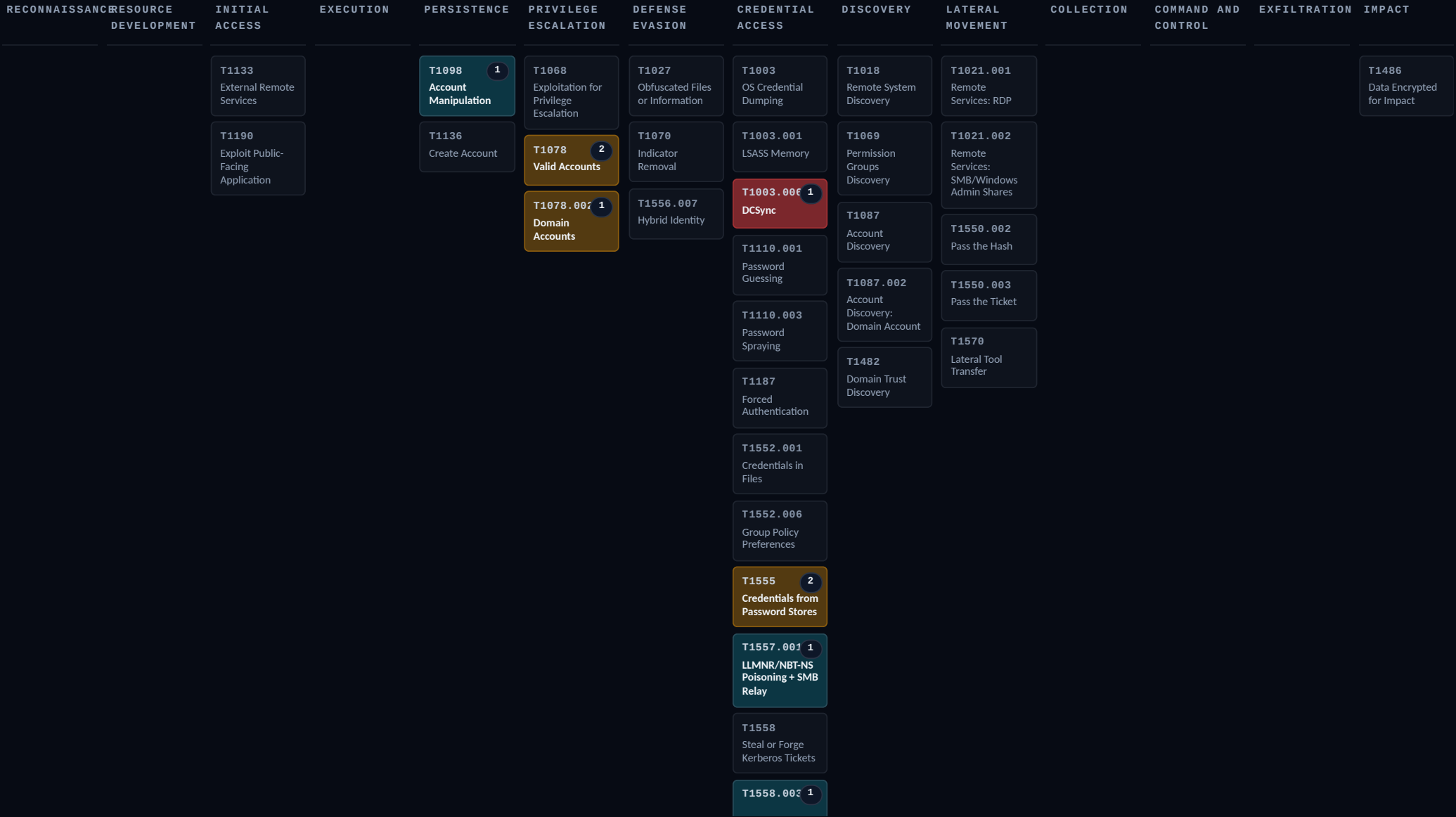
04 MITRE ATT&CK Coverage

Techniques exercised across the identified attack surface.

TECHNIQUE	NAME	LINKED FINDINGS
T1003.006	OS Credential Dumping: DCSync	DCSync Privilege Abuse
T1078	Valid Accounts	Accounts with Non-Expiring Passwords, Passwords Predating Current Policy
T1078.002	Valid Accounts: Domain Accounts	Domain Admin Sessions on Non-Privileged Hosts
T1098	Account Manipulation	All Extended Rights Assigned
T1210	Exploitation of Remote Services	SMBv1 Protocol Enabled
T1555	Credentials from Password Stores	gMSA Password Readable by Non-Admins, LAPS Password Readable by Non-Admins
T1557.001	LLMNR/NBT-NS Poisoning and SMB Relay	SMB Signing Not Required
T1558.003	Steal or Forge Kerberos Tickets: Kerberoasting	Kerberoasting
T1558.004	Steal or Forge Kerberos Tickets: AS-REP Roasting	AS-REP Roasting
T1649	Steal or Forge Authentication Certificates	ADCS ESC9 - No Security Extension on Certificate Template, ADCS ESC14 - Weak Explicit Certificate Mapping Abuse, ADCS ESC1 - Misconfigured Certificate Template, ADCS ESC13 - Issuance Policy with Group Link Abuse, ADCS ESC2 - Any Purpose Certificate Template, ADCS ESC3 - Enrollment Agent Template Abuse, ADCS ESC8 - NTLM Relay to Web Enrollment, ADCS ESC5 - Vulnerable CA Object ACL, ADCS ESC7 - Certificate Authority Privilege Abuse, ADCS ESC4 - Vulnerable Certificate Template ACL

10 techniques observed across 3 tactics

Density mapped to MITRE ATT&CK · darker cells indicate higher finding concentration or more severe exposure.



Density  none → low → moderate → high

Kerberoasting

T1558.004 1
AS-REP Roasting

T1649 10
Steal or Forge
Authentication
Certificates

T1210 1
T1210

10 techniques · 3 tactics · 22 findings

How the attack chain unfolded

Earliest tactic to most recent · severity-coded · catalog-aligned to MITRE ATT&CK.

PERSISTENCE

	T1098	Account Manipulation	1 finding	MEDIUM
---	-------	----------------------	-----------	--------

PRIVILEGE ESCALATION

	T1078.002	Domain Accounts	1 finding	HIGH
---	-----------	-----------------	-----------	------

	T1078	Valid Accounts	2 findings	LOW
---	-------	----------------	------------	-----

CREDENTIAL ACCESS

	T1003.006	DCSync	1 finding	CRITICAL
---	-----------	--------	-----------	----------

	T1210	T1210	1 finding	HIGH
---	-------	-------	-----------	------

	T1555	Credentials from Password Stores	2 findings	HIGH
---	-------	----------------------------------	------------	------

	T1649	Steal or Forge Authentication Certificates	10 findings	HIGH
--	-------	--	-------------	------

	T1557.001	LLMNR/NBT-NS Poisoning + SMB Relay	1 finding	MEDIUM
---	-----------	------------------------------------	-----------	--------

	T1558.003	Kerberoasting	1 finding	MEDIUM
---	-----------	---------------	-----------	--------

	T1558.004	AS-REP Roasting	1 finding	MEDIUM
---	-----------	-----------------	-----------	--------

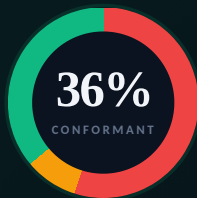
The assessment surfaced 1 critical finding mapped to 10 ATT&CK techniques across 3 tactics. While no end-to-end path to Domain Admin was validated, the highlighted techniques represent realistic stepping stones an attacker would chain in a follow-up engagement.

05 ENS — Esquema Nacional de Seguridad

ENS security measures affected by the assessment findings.

ENS — Esquema Nacional de Seguridad

The Esquema Nacional de Seguridad (ENS), established by Royal Decree 311/2022, is the mandatory security framework for Spanish public-sector organisations and their digital service providers. Active Directory weaknesses directly affect access control, identity management, and service protection domains.



6

NON-CONFORMANT

1

PARTIAL

4

CONFORMANT

11

CONTROLS ASSESSED

CERTIFICATION RISK • HIGH

6 major non-conformities identified. Address before the next certification or surveillance audit.

MARCO ORGANIZATIVO

1 controls • 1 non-conformant • 0 conformant

MARCO OPERACIONAL

8 controls • 4 non-conformant • 1 partial • 3 conformant

MEDIDAS DE PROTECCIÓN

2 controls • 1 non-conformant • 1 conformant

Non-conformity Summary

Gaps classified by audit severity. Major non-conformities typically trigger corrective action requests (CARs) in certification audits.

MAJOR NON-CONFORMITIES			MINOR NON-CONFORMITIES / OBSERVATIONS		
op.acc.3	Segregación de funciones y tareas	9.8	op.acc.2	Requisitos de acceso	0.0
op.acc.4	Proceso de gestión de derechos de acceso	9.8			
op.acc.5	Mecanismo de autenticación	8.5			
org.4	Proceso de autorización	8.5			
mp.com.3	Protección de la autenticidad y la integridad	8.2			
op.acc.6	Acceso local (administradores)	8.0			

Major non-conformities: CVSS ≥ 7.0 . Minor non-conformities: CVSS < 7.0 or attack paths only. Classification is indicative; auditor judgment may differ.

Control Assessment

Controls sorted by conformity status. Non-conformant controls carry the highest audit risk.

op.acc.3 MARCO OPERACIONAL NON-CONFORMANT - MAJOR Segregación de funciones y tareas Los privilegios de acceso deben estar segregados para evitar concentraciones de poder que puedan ser abusadas. AFFECTED FINDINGS DCSync Privilege Abuse8.8 ADCS ESC7 - Certificate Authority Privilege Abuse8.5 Domain Admin Sessions on Non-Privileged Hosts8.0 All Extended Rights Assigned6.5	op.acc.4 MARCO OPERACIONAL NON-CONFORMANT - MAJOR Proceso de gestión de derechos de acceso Los derechos de acceso se gestionarán de acuerdo a las necesidades del servicio y se revisarán periódicamente. AFFECTED FINDINGS DCSync Privilege Abuse8.8 LAPS Password Readable by Non-Admins7.5 gMSA Password Readable by Non-Admins7.5 All Extended Rights Assigned6.5 Kerberoasting5.3
op.acc.5 MARCO OPERACIONAL NON-CONFORMANT - MAJOR Mecanismo de autenticación El sistema implementa mecanismos de autenticación robustos que impidan el acceso de usuarios no autorizados. AFFECTED FINDINGS ADCS ESC1 - Misconfigured Certificate Template8.5 ADCS ESC13 - Issuance Policy with Group Link Abuse8.5 ADCS ESC14 - Weak Explicit Certificate Mapping Abuse8.5 ADCS ESC2 - Any Purpose Certificate Template8.5 ADCS ESC3 - Enrollment Agent Template Abuse8.5 +9 more	org.4 MARCO ORGANIZATIVO NON-CONFORMANT - MAJOR Proceso de autorización Se mantendrá un proceso formal de autorización para el acceso a los sistemas y para las operaciones privilegiadas. AFFECTED FINDINGS ADCS ESC1 - Misconfigured Certificate Template8.5 ADCS ESC2 - Any Purpose Certificate Template8.5 ADCS ESC3 - Enrollment Agent Template Abuse8.5 ADCS ESC4 - Vulnerable Certificate Template ACL8.5 ADCS ESC5 - Vulnerable CA Object ACL8.5
mp.com.3 MEDIDAS DE PROTECCIÓN NON-CONFORMANT - MAJOR Protección de la autenticidad y la integridad Se garantizará la autenticidad del origen y la integridad de la información intercambiada entre sistemas. AFFECTED FINDINGS ADCS ESC8 - NTLM Relay to Web Enrollment8.2 THEORETICAL BRAAVOS\$@ESSOS.LOCAL -> ADSCAN@ESSOS.LOCAL THEORETICAL BRAAVOS\$@ESSOS.LOCAL -> ESSOS.LOCAL UNSUPPORTED BRAAVOS\$@ESSOS.LOCAL -> ESSOS.LOCAL	op.acc.6 MARCO OPERACIONAL NON-CONFORMANT - MAJOR Acceso local (administradores) El acceso físico y lógico de los administradores debe ser controlado, registrado y restringido al mínimo necesario. AFFECTED FINDINGS Domain Admin Sessions on Non-Privileged Hosts8.0 LAPS Password Readable by Non-Admins7.5
op.acc.2 MARCO OPERACIONAL PARTIALLY CONFORMANT - MINOR Requisitos de acceso Los recursos del sistema dispondrán de los controles de acceso adecuados que impidan el acceso no autorizado. THEORETICAL BRAAVOS\$@ESSOS.LOCAL -> ADSCAN@ESSOS.LOCAL THEORETICAL BRAAVOS\$@ESSOS.LOCAL -> ESSOS.LOCAL UNSUPPORTED BRAAVOS\$@ESSOS.LOCAL -> ESSOS.LOCAL	op.acc.1 MARCO OPERACIONAL CONFORMANT Identificación de usuarios Todos los usuarios con acceso al sistema deben estar identificados de forma única y no compartir identidades. No gaps identified — control appears effective.
op.exp.2 MARCO OPERACIONAL CONFORMANT Configuración de seguridad Los sistemas deben ser configurados minimizando su exposición a amenazas, desactivando funcionalidades innecesarias. No gaps identified — control appears effective.	op.exp.4 MARCO OPERACIONAL CONFORMANT Mantenimiento y actualizaciones de seguridad Se aplicarán las actualizaciones de seguridad de forma regular y oportuna, minimizando la ventana de exposición. No gaps identified — control appears effective.

mp.com.2

MEDIDAS DE PROTECCIÓN

CONFORMANT

Protección de la confidencialidad

La información transmitida a través de redes o almacenada en sistemas debe protegerse contra accesos no autorizados.

No gaps identified — control appears effective.

CERTIFICATION & AUDIT IMPACT

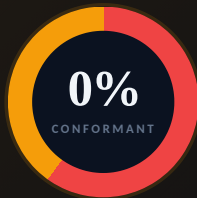
The 6 major non-conformities identified (e.g. op.acc.3, op.acc.4, op.acc.5) would each constitute a corrective action request (CAR) during a ENS certification or surveillance audit. The 1 minor non-conformity may result in observations or minor CARs at auditor discretion. Organizations with active certification must address major non-conformities before the next audit cycle to avoid suspension or withdrawal of certification.

06 DORA Compliance

DORA ICT risk management obligations affected by AD security findings.

DORA — Digital Operational Resilience Act

DORA focuses on ICT risk management and operational resilience for financial entities. Active Directory attack paths and identity control gaps indicate where compromise could disrupt critical ICT services and trigger reporting obligations.



6

NON-CONFORMANT

4

PARTIAL

0

CONFORMANT

10

CONTROLS ASSESSED

CERTIFICATION RISK • HIGH

6 major non-conformities identified. Address before the next certification or surveillance audit.

ICT RISK MANAGEMENT

6 controls • 3 non-conformant • 3 partial • 0 conformant

RESILIENCE & RECOVERY

1 controls • 1 non-conformant • 0 conformant

INCIDENT MANAGEMENT

2 controls • 2 non-conformant • 0 conformant

GOVERNANCE

1 controls • 1 partial • 0 conformant

Non-conformity Summary

Gaps classified by audit severity. Major non-conformities typically trigger corrective action requests (CARs) in certification audits.

MAJOR NON-CONFORMITIES

art_9_2	Protection — access control	9.8
art_9_4	Protection — identity & MFA	9.8
art_11	Response and recovery	9.8
art_17	ICT-related incident management process	9.8
art_19	Reporting of major ICT-related incidents	9.8
art_9_3	Protection — network security	8.2

MINOR NON-CONFORMITIES / OBSERVATIONS

art_6	ICT risk management framework	6.9
art_5	Governance and organisation	3.7
art_8	Identification	0.0
art_10	Detection	0.0

Major non-conformities: CVSS ≥ 7.0. Minor non-conformities: CVSS < 7.0 or attack paths only. Classification is indicative; auditor judgment may differ.

Control Assessment

Controls sorted by conformity status. Non-conformant controls carry the highest audit risk.

art_9_2 ICT RISK MANAGEMENT NON-CONFORMANT - MAJOR Protection — access control Financial entities must implement access control policies based on least-privilege principles, ensuring that access to systems is granted only as necessary for ... AFFECTED FINDINGS DCSync Privilege Abuse9.8 LAPS Password Readable by Non-Admins7.5 gMSA Password Readable by Non-Admins7.5 All Extended Rights Assigned6.5	art_9_4 ICT RISK MANAGEMENT NON-CONFORMANT - MAJOR Protection — identity & MFA Financial entities must implement strong authentication mechanisms. Per Art. 9(4) and Commission Delegated Regulation (EU) 2024/1774, this explicitly requires: ... AFFECTED FINDINGS DCSync Privilege Abuse9.8 ADCS ESC1 - Misconfigured Certificate Template8.5 ADCS ESC13 - Issuance Policy with Group Link Abuse8.5 ADCS ESC14 - Weak Explicit Certificate Mapping Abuse8.5 ADCS ESC2 - Any Purpose Certificate Template8.5 +11 more
art_11 RESILIENCE & RECOVERY NON-CONFORMANT - MAJOR Response and recovery Financial entities must implement a dedicated ICT business continuity policy that enables rapid response to, and recovery from, major ICT-related incidents. Thi... AFFECTED FINDINGS DCSync Privilege Abuse9.8	art_17 INCIDENT MANAGEMENT NON-CONFORMANT - MAJOR ICT-related incident management process Financial entities must define, establish and implement an ICT-related incident management process to detect, manage and notify ICT-related incidents. This is t... AFFECTED FINDINGS DCSync Privilege Abuse9.8 ADCS ESC1 - Misconfigured Certificate Template8.5
art_19 INCIDENT MANAGEMENT NON-CONFORMANT - MAJOR Reporting of major ICT-related incidents Financial entities must report major ICT-related incidents to the relevant competent authority. Per Art. 19 and Commission Delegated Regulation (EU) 2025/301, t... AFFECTED FINDINGS DCSync Privilege Abuse9.8 ADCS ESC1 - Misconfigured Certificate Template8.5	art_9_3 ICT RISK MANAGEMENT NON-CONFORMANT - MAJOR Protection — network security Financial entities must have in place security measures against network intrusions and data misuse. This includes network segmentation, perimeter protections, a... AFFECTED FINDINGS ADCS ESC8 - NTLM Relay to Web Enrollment8.2 THEORETICAL BRAAVOS\$@ESSOS.LOCAL -> ADSCAN@ESSOS.LOCAL THEORETICAL BRAAVOS\$@ESSOS.LOCAL -> ESSOS.LOCAL UNSUPPORTED BRAAVOS\$@ESSOS.LOCAL -> ESSOS.LOCAL
art_6 ICT RISK MANAGEMENT PARTIALLY CONFORMANT - MINOR ICT risk management framework Financial entities must have a sound, comprehensive and well-documented ICT risk management framework as part of their overall risk management system. The frame... AFFECTED FINDINGS AS-REP Roasting6.9 Kerberoasting5.3 Accounts with Non-Expiring Passwords3.7	art_5 GOVERNANCE PARTIALLY CONFORMANT - MINOR Governance and organisation The management body of the financial entity must define, approve, oversee and be accountable for the implementation of all arrangements related to the ICT risk ... AFFECTED FINDINGS Accounts with Non-Expiring Passwords3.7
art_8 ICT RISK MANAGEMENT PARTIALLY CONFORMANT - MINOR Identification Financial entities must identify, classify and adequately document all ICT supported business functions, roles and responsibilities, information assets and ICT ... THEORETICAL BRAAVOS\$@ESSOS.LOCAL -> ADSCAN@ESSOS.LOCAL THEORETICAL BRAAVOS\$@ESSOS.LOCAL -> ESSOS.LOCAL UNSUPPORTED BRAAVOS\$@ESSOS.LOCAL -> ESSOS.LOCAL	art_10 ICT RISK MANAGEMENT PARTIALLY CONFORMANT - MINOR Detection Financial entities must have mechanisms to promptly detect anomalous activities, including ICT network performance and ICT-related incidents. Detection mechanis... THEORETICAL BRAAVOS\$@ESSOS.LOCAL -> ADSCAN@ESSOS.LOCAL THEORETICAL BRAAVOS\$@ESSOS.LOCAL -> ESSOS.LOCAL UNSUPPORTED BRAAVOS\$@ESSOS.LOCAL -> ESSOS.LOCAL

07 Attack Path Remediation Priorities

Ranked actions that eliminate the maximum number of attack paths per remediation effort.

The following analysis identifies which attack techniques and vulnerabilities appear across the most attack paths. Addressing the top items first maximises exposure reduction per unit of remediation effort — a single fix can close multiple independent compromise routes simultaneously.

HIGHEST-IMPACT SINGLE REMEDIATION

Eliminating **Attribute Write (GenericWrite)** would directly close **10 attack paths (67%)** of all identified compromise routes. This remediation is assessed as **Medium complexity**.

Attack Technique Priorities

Each row represents one attack technique type found across multiple paths. "Paths Eliminated" shows how many attack paths would be disrupted by addressing it.

#	TECHNIQUE	PATHS ELIMINATED	AFFECTED PRINCIPALS	REMEDIATION GUIDANCE
1	Attribute Write (GenericWrite) T1098 · Account Manipulation	10 paths 67% of total	1 principal	MEDIUM Remove GenericWrite permission from the target object ACL. Replace broad write rights with specific delegated attributes only. - Remove the GenericWrite ACE from {source} on {target}. - Audit msDS-KeyCredentialLink writes (Event 5136) to detect Shadow Credentials.
2	Group Membership Privilege	8 paths 53% of total	1 principal	LOW Remove the user/group from the over-privileged group. - Remove {source} from {target} if the membership is not strictly required. - Audit group membership periodically and enforce tiering boundaries.
3	Aspreoasting T1558.004 · Steal or Forge Kerberos Tickets: AS-REP Roasting	8 paths 53% of total	1 principal	LOW Enable Kerberos pre-authentication on all accounts (UF_DONT_REQUIRE_PREAUTH must not be set). - Enable Kerberos pre-authentication for {target} (clear DONT_REQ_PREAUTH in userAccountControl). - Enforce strong passwords on accounts that must keep pre-auth disabled. - Monitor Event ID 4768 with pre-authentication type 0 for anomalous requests.
4	Full Object Control (GenericAll) T1098 · Account Manipulation	6 paths 40% of total	1 principal	MEDIUM Remove GenericAll permission from the target object ACL. Audit AD ACLs regularly using tools such as BloodHound or ADACLScanner. Apply least-privilege delegation. - Remove the GenericAll ACE granting control from {source} over {target}. - Apply least privilege: replace with narrow rights (e.g. ReadProperty) if some access is still required. - Enable AD Protected Users / tier-0 protection on sensitive accounts.
5	LAPS Password Read T1555 · Credentials from Password Stores	5 paths 33% of total	1 principal	LOW Restrict read access on ms-Mcs-AdmPwd (legacy LAPS) or msLAPS-Password (Windows LAPS) to authorized IT admin groups only via AD ACL. - Remove the Control Access ACE on ms-Mcs-AdmPwd / ms-LAPS-Password from {source} on {target}. - Audit LDAP reads of ms-LAPS-Password via Event ID 4662 with the LAPS GUID.

#	TECHNIQUE	PATHS ELIMINATED	AFFECTED PRINCIPALS	REMEDIATION GUIDANCE
6	LSA Secrets Dump T1003.004 · OS Credential Dumping: LSA Secrets	5 paths 33% of total	1 principal	MEDIUM Restrict local admin access to servers. Enable LSA Protection (RunAsPPL). Deploy EDR with credential dump detection.
7	DCSync (Domain Replication) T1003.006 · OS Credential Dumping: DCSync	4 paths 27% of total	1 principal	MEDIUM Remove GetChanges (DS-Replication-Get-Changes) and GetChangesAll (DS-Replication-Get-Changes-All) permissions from all non-DC accounts on the domain naming context object. - Remove DS-Replication-Get-Changes and DS-Replication-Get-Changes-All extended rights from {source} on the domain. - Limit these rights to DCs and approved replication service accounts only. - Alert on DCSync via Event ID 4662 with the replication GUIDs from non-DC sources.
8	Canrdp T1021.001 · Remote Services: Remote Desktop Protocol	2 paths 13% of total	1 principal	MEDIUM Remove the principal from the Remote Desktop Users group on target hosts. Restrict RDP access via GPO and firewall rules.
9	Adcsesc9 T1649 · Steal or Forge Authentication Certificates	2 paths 13% of total	1 principal	HIGH Deploy KB5014754 and set StrongCertificateBindingEnforcement=2 on all DCs. Restrict write access to UPN attributes. Requires thorough testing before full enforcement.
10	Hassession T1053.005 · Scheduled Task/Job: Scheduled Task	1 path 7% of total	1 principal	MEDIUM Restrict Domain Admin logons to Tier 0 assets only. Use PAWs for privileged operations and prohibit DA logons on member servers/workstations. Enforce ESAE/PAW model and monitor tier-zero session exposure.
11	Adcsesc5 T1649 · Steal or Forge Authentication Certificates	1 path 7% of total	1 principal	MEDIUM Restrict ACL permissions on CA objects and PKI containers in AD. Remove non-privileged write access to CA configuration objects.
12	Adcsesc7 T1649 · Steal or Forge Authentication Certificates	1 path 7% of total	1 principal	HIGH Remove the ManageCA or ManageCertificates rights from non-privileged principals. Audit CA officer and manager role assignments.

Vulnerability Impact on Attack Paths

Detected vulnerabilities ranked by the number of attack paths they directly enable. Patching these findings disrupts the corresponding attack chains.

VULNERABILITY	CVSS	PATHS ENABLED	DOMAIN(S)
AS-REP Roasting asreproast	6.9	8 paths 53% of total	essos.local
LAPS Password Readable by Non-Admins laps_readable	7.5	5 paths 33% of total	essos.local
DCSync Privilege Abuse dcsync	9.8	4 paths 27% of total	essos.local
ADCS ESC9 - No Security Extension on Certificate Template adcs_esc9	8.5	2 paths 13% of total	essos.local
ADCS ESC7 - Certificate Authority Privilege Abuse adcs_esc7	8.5	1 path 7% of total	essos.local

VULNERABILITY	CVSS	PATHS ENABLED	DOMAIN(S)
ADCS ESC5 - Vulnerable CA Object ACL adcs_esc5	8.5	1 path 7% of total	essos.local
Domain Admin Sessions on Non-Privileged Hosts da_sessions	8.0	1 path 7% of total	essos.local

08 Remediation Roadmap

Prioritised action plan to reduce risk across the environment.

IMMEDIATE • 0-30 DAYS

Contain critical exposure

- **DCSync Privilege Abuse** · [essos.local](#) · CVSS 9.8
- **ADCS ESC9 - No Security Extension on Certificate Template** · [essos.local](#) · CVSS 8.5
- **ADCS ESC14 - Weak Explicit Certificate Mapping Abuse** · [essos.local](#) · CVSS 8.5
- **ADCS ESC1 - Misconfigured Certificate Template** · [essos.local](#) · CVSS 8.5
- **ADCS ESC13 - Issuance Policy with Group Link Abuse** · [essos.local](#) · CVSS 8.5
- **ADCS ESC2 - Any Purpose Certificate Template** · [essos.local](#) · CVSS 8.5
- **ADCS ESC3 - Enrollment Agent Template Abuse** · [essos.local](#) · CVSS 8.5
- **ADCS ESC5 - Vulnerable CA Object ACL** · [essos.local](#) · CVSS 8.5
- **ADCS ESC7 - Certificate Authority Privilege Abuse** · [essos.local](#) · CVSS 8.5
- **ADCS ESC4 - Vulnerable Certificate Template ACL** · [essos.local](#) · CVSS 8.5
- **ADCS ESC8 - NTLM Relay to Web Enrollment** · [essos.local](#) · CVSS 8.2
- **Domain Admin Sessions on Non-Privileged Hosts** · [essos.local](#) · CVSS 8.0
- **gMSA Password Readable by Non-Admins** · [essos.local](#) · CVSS 7.5
- **LAPS Password Readable by Non-Admins** · [essos.local](#) · CVSS 7.5
- **SMBv1 Protocol Enabled** · [essos.local](#) · CVSS 7.5

SHORT-TERM • 30-90 DAYS

Reduce attack surface

- **AS-REP Roasting** · [essos.local](#) · CVSS 6.9
- **All Extended Rights Assigned** · [essos.local](#) · CVSS 6.5
- **Kerberoasting** · [essos.local](#) · CVSS 5.3
- **SMB Signing Not Required** · [essos.local](#) · CVSS 5.0

LONG-TERM • 90+ DAYS

Harden baseline

- **Accounts with Non-Expiring Passwords** · [essos.local](#)
- **Machine Account Quota Allows Domain Join** · [essos.local](#)
- **Passwords Predating Current Policy** · [essos.local](#)